

Project closure

SecureGate was built by Team Nexora for Microsoft Innovate 2026, Problem Statement 24, between 2026-09-30 and 2026-10-07, and closed out on 2026-10-10 as version 1.0.0. It is finished, not shut down: anyone can clone it, set it up, run it, and protect their own repository with it. It is not actively maintained.

What was built, and works today

Part	What it does	Try it
Find and decide	Gitleaks, and with <code>--scanners all</code> also TruffleHog, Semgrep and Bandit, find possible secrets; <code>policy.yaml</code> decides block, warn or ignore; every output shows masked values only; the exit code is 0, 1 or 2	<code>make demo</code> , then <code>make scan-demo</code>
The demo project	DemoPay, a fake payments app with 9 planted secrets and 11 decoys, and an answer sheet for the scorecard	<code>make demo</code> , then <code>make test</code>
The dashboard	The report in the browser, read-only, on this computer only, with downloads and a printable report	<code>make ui</code>
The menu	Everything above without typing commands	double-click <code>Start SecureGate.cmd</code> , or <code>make menu</code>
The laptop gate	Scans the staged changes before every commit	<code>make hooks</code>
The merge gate	Scans every commit of every pull request to main with all four scanners, comments, and locks the merge button when the check is red	open a pull request; see The two gates (merge-gate.pdf)
The GitHub Action	The same merge gate for any repository	<code>uses: Bhavik-Kadian/Nexora@v1.0.0</code> ; see Protect any repository (install.pdf)
The demo kit	Five real demo pull requests, clean-up, <code>doctor</code> and <code>ci-report</code>	menu choice 9; see Demo: the merge gate (demo-script.pdf)
The AI agents	Triage, fix and incident advice on Azure AI Foundry; advice only, never a whole secret	menu choice A; see The AI agents (agents.pdf)

The AI agents were verified on Azure on 2026-10-07, from the laptop, on a `gpt-5-mini` deployment: the connection check passed, and on the demo scan they gave 11 triage notes, 3 suggested fixes and a 10-step incident plan in about 75 seconds. In this repository's merge gate the agents' step is in place, but the repository has no `SECUREGATE_AI_KEY` secret, so the gate's comments say the agents were not asked. The two gates (merge-gate.pdf) says how to turn them on.

Known limitations

The full list, with what to do about each, is in Limitations (limitations.pdf). The main ones:

- **The scorecard is honest, not perfect.** With all four scanners, 16 of the 20 planted lines get the expected decision. A password inside a `Dockerfile` is missed, an AWS secret key next to its key id gets a warning instead of a block, and two decoys (an id and a commit hash) get warnings.
- **A pull request can edit the workflow that judges it.** The rules come from main, but GitHub runs the pull request's own copy of the workflow. A required Code Owners review would close this; it needs a second maintainer.

- **ACME Pay tokens cannot be checked for being live**, because the live-checks layer was never built (Roadmap (roadmap.pdf)).
- **Pull requests from forks** get no comment, no Security-tab results and no AI advice. Their check still decides.
- **Semgrep needs the internet** for its p/secrets rules, and Semgrep and Bandit are pinned by version, not by checksum.
- **Windows first.** Start `SecureGate.cmd` is for Windows; on macOS and Linux, `make menu` opens the same menu.

What was switched off at the close-out

- **The demo pull requests.** The 11 that were still open (#6 and #9 to #18) were closed, and their `demo/` branches deleted, here and on the laptop. They held fake ACME Pay tokens only. GitHub keeps closed pull requests, which is harmless.
- **Merged branches** were deleted: the work of each stage is in main.
- **The old Nexora repository** was renamed to Nexora-backup. It only held copies of early branches.

Nothing else was switched off. The merge gate stays on for every pull request. Azure stays up. There was no scheduled workflow, such as a nightly sweep, to switch off.

How to bring each part back

Part	How
The demo pull requests	<code>make demo-leak</code> (or menu 9, then 2), and the other four scenes. They need <code>gh</code> , signed in, and a clean working tree. <code>make demo-cleanup</code> closes them again.
The AI agents in pull request comments	Set the repository secret <code>SECUREGATE_AI_KEY</code> and the variables <code>SECUREGATE_AI_ENDPOINT</code> and <code>SECUREGATE_AI_DEPLOYMENT</code> : "The AI agents" in The two gates (merge-gate.pdf).
The AI agents, after the Azure resource is deleted	Create a new Azure AI Foundry resource and deployment, then <code>securegate ai-setup</code> and <code>securegate ai-check</code> : "Set them up" in The AI agents (agents.pdf).
The ruleset, if it is ever removed	"The one-time setting" in The two gates (merge-gate.pdf), by hand or with its one command.
The ACME Pay provider and live checks	They were never built, so there is nothing to run or redeploy. The approved plan to build them is kept in History (docs/history/plan-live-checks-not-built.md in the repository).
A nightly sweep	There never was one. The Roadmap (roadmap.pdf) says how to add one; until then, run <code>securegate scan . --mode repo --scanners all</code> by hand.
The scanners, on a new computer	<code>make scanners</code> (after step 1 of Getting started (getting-started.pdf)).

Final test and scan results

Measured on 2026-10-10, on the close-out branch, on Windows 11 with Python 3.12.10:

Check	Result
<code>make check</code> (ruff, then the tests)	1034 passed, 1 skipped: a test of POSIX file modes, which Windows does not have
Scorecard, the demo project with all four scanners	16 of 20 planted lines as expected: 1 miss, 1 wrong decision, 2 false alarms

Check	Result
Scorecard, Gitleaks alone	15 of 20 as expected: 2 misses, 1 wrong decision, 2 false alarms
<code>make demo</code> , then <code>make scan-demo</code>	SecureGate exits with code 1, which <code>make</code> reports as Error 1 : 11 findings (6 block, 4 warn, 1 ignore), every value masked
<code>gitleaks git</code> over every branch's history	11 findings, all fake ACME Pay tokens, one on each of the 11 demo branches; nothing on main or on any other branch
<code>securegate scan . --mode repo</code>	exit code 1 while the demo branches existed, for those same fake tokens only
Links between the Markdown pages	0 broken, checked by <code>tests/test_docs_links.py</code>

After publishing

Measured on 2026-10-10, after the close-out pull request (#19) was merged and `v1.0.0` was released:

Check	Result
A fresh clone of <code>github.com/Bhavik-Kadian/Nexora</code> , at the <code>v1.0.0</code> tag, then <code>make setup</code> and <code>make check</code>	1027 passed, 6 skipped: the POSIX test, and 5 tests of the real TruffleHog, Semgrep and Bandit, which <code>make scanners</code> installs
<code>make demo</code> , then <code>make scan-demo</code> , in that clone	SecureGate exits with code 1 (Error 1): 11 findings (6 block, 4 warn, 1 ignore), every value masked
<code>securegate scan . --mode repo</code> , in that clone	exit code 0, no findings: the demo branches are gone
The merge gate on the close-out pull request	green: every commit scanned by all four scanners, on <code>ubuntu-24.04</code>
The GitHub Action, on real pull requests in securegate-action-demo	a harmless change passed; a fake ACME Pay token was blocked by rule 8, shown masked, and that pull request was closed; then the action at <code>@v1.0.0</code> passed
<code>make doctor</code> , on the laptop	all 12 checks pass, among them "main cannot be merged until secret-gate passes"
The release	v1.0.0 , the latest release

Where everything is

- **The code, the docs and the release:** github.com/Bhavik-Kadian/Nexora, release `v1.0.0`. Every page is also a PDF in `docs/pdf/`.
- **On GitHub:** the ruleset "Protect main" (every change through a pull request whose `secret-gate` check passed, and nobody can bypass it), private vulnerability reporting for SECURITY.md (SECURITY.md in the repository), and the repository's description and topics.
- **What is left for the owner to do:** CLOSEOUT-CHECKLIST.md (CLOSEOUT-CHECKLIST.md in the repository).
- **What changed, stage by stage:** CHANGELOG.md (CHANGELOG.md in the repository).
- **The working notes of the build:** History (docs/history/README.md in the repository).